

Systeme de Détection de Spam et Phishing

Basé sur l'IA et les Indicateurs de Compromission (IoCs)

Projet Cybersécurité - Personne A

Analyse des Menaces et Ingénierie des IoCs

Encadré par Pr. Sara Ouald Chaib

2026

Table des matières

1 Introduction

L'objectif principal de ce projet est de concevoir un système intelligent capable de détecter les emails malveillants à travers une approche orientée cybersécurité.

Contrairement à une approche purement centrée sur le Machine Learning, ce projet considère le spam et le phishing comme de véritables cyberattaques exploitant des mécanismes techniques et psychologiques afin de compromettre un système d'information.

Le système proposé vise donc à :

- Identifier les emails frauduleux
- Détecter les tentatives de phishing
- Analyser les comportements malveillants
- Construire des Indicateurs de Compromission (IoCs)
- Fournir des données pertinentes aux modèles de détection

Cette approche s'aligne directement avec les concepts étudiés dans le module de cybersécurité :

- Ingénierie sociale
- Phishing
- Filtrage réseau
- Architecture défensive
- Détection d'intrusions
- Analyse comportementale

2 Analyse des Menaces

2.1 Cybermenace vs Cyberattaque

Une cybermenace représente un danger potentiel permanent pouvant affecter un système d'information.

Une cyberattaque représente le passage à l'action. Elle vise généralement :

- La confidentialité
- L'intégrité
- La disponibilité

Dans le contexte des emails malveillants, les attaques exploitent principalement :

- La manipulation psychologique
- L'usurpation d'identité
- Les redirections malveillantes
- Les pièces jointes piégées

2.2 Spam Traditionnel

Le spam correspond à l'envoi massif de messages non sollicités.

2.2.1 Objectifs du Spam

Les objectifs principaux sont :

- Saturation des systèmes
- Publicité frauduleuse
- Diffusion massive de liens
- Escroqueries simples

2.2.2 Impact Sécurité

Le spam impacte principalement :

- La disponibilité du système
- Les performances réseau
- La productivité des utilisateurs

Le risque de compromission directe reste relativement faible comparé au phishing.

2.3 Phishing et Spear Phishing

Le phishing est une technique d'ingénierie sociale visant à tromper la victime afin d'obtenir :

- Des identifiants
- Des données bancaires
- Des informations sensibles
- Une exécution de malware

2.3.1 Ingénierie Sociale

L'ingénierie sociale exploite :

- La peur
- L'urgence
- La confiance
- L'autorité

L'objectif est de pousser l'utilisateur à agir rapidement sans vérifier l'authenticité du message.

2.3.2 Spear Phishing

Le spear phishing est une version ciblée du phishing.

L'attaquant personnalise l'email pour :

- Un employé précis
- Un directeur
- Une organisation spécifique

Ces attaques sont beaucoup plus difficiles à détecter.

3 Comportement Adaptatif des Attaquants

Les cybercriminels adaptent constamment leurs techniques afin de contourner les systèmes de sécurité.

Les filtres statiques basés uniquement sur des mots-clés deviennent rapidement inefficaces.

Les attaquants utilisent notamment :

- L’obfuscation Unicode
- Les caractères invisibles
- Les domaines générés aléatoirement
- Les homoglyphes
- Les redirections multiples
- Le spoofing

Le système doit donc détecter :

- Les anomalies structurelles
 - Les comportements suspects
 - Les indicateurs comportementaux
- et non uniquement des signatures fixes.

4 Architecture de Défense Multi-Couches

Le système d’analyse des emails a été conçu comme une architecture de filtrage multi-couches.

Chaque couche joue un rôle spécifique dans la détection des menaces.

4.1 Principe du Filtrage Multi-Couches

Le principe consiste à analyser simultanément plusieurs surfaces d’attaque :

1. Les headers
2. Les URLs
3. Le contenu textuel
4. Les comportements psychologiques
5. Les métadonnées
6. Les pièces jointes

Même si une couche est contournée, les autres couches peuvent toujours détecter l’attaque.

5 Indicateurs de Compromission (IoCs)

Les Indicateurs de Compromission représentent des éléments observables permettant d’identifier une activité potentiellement malveillante.

Dans ce projet, les IoCs sont utilisés comme caractéristiques d’entrée pour les modèles de Machine Learning.

5.1 Header-Based IoCs

Ces indicateurs analysent les anomalies liées au routage et à l'authentification des emails.

5.1.1 Reply-To Mismatch

Le Reply-To Mismatch correspond à une différence entre :

- L'adresse d'expédition
- L'adresse de réponse

Cette technique est fréquemment utilisée dans les attaques de spoofing.

5.1.2 SPF, DKIM et DMARC

SPF Le SPF (Sender Policy Framework) permet de vérifier si le serveur expéditeur est autorisé à envoyer des emails pour un domaine donné.

DKIM Le DKIM (DomainKeys Identified Mail) ajoute une signature cryptographique permettant de vérifier l'intégrité du message.

DMARC Le DMARC définit la politique appliquée lorsqu'un email échoue aux vérifications SPF ou DKIM.

Un défaut d'alignement SPF/DKIM/DMARC constitue un IoC critique.

5.2 URL-Based IoCs

Les URLs représentent l'un des principaux vecteurs d'attaque dans les campagnes de phishing.

5.2.1 IP-Based URLs

Les attaquants utilisent parfois directement des adresses IP afin de contourner :

- Les filtres DNS
- Les listes noires
- Les systèmes de réputation

Exemple :

`http://192.168.1.25/login`

5.2.2 TLDs Suspects

Certains domaines génériques sont fréquemment utilisés dans les campagnes malveillantes :

- .xyz
- .top
- .click
- .shop

Ces domaines constituent donc des indicateurs de risque.

5.2.3 Homoglyphes

Les homoglyphes consistent à remplacer certains caractères par des symboles visuellement similaires.

Exemple :

paypaI.com

Le caractère "I" majuscule remplace la lettre "l".

Cette technique vise à tromper visuellement la victime.

5.2.4 Entropie des Domaines

Les domaines générés automatiquement possèdent souvent une forte entropie.

Exemple :

xj82ks91-top-security.xyz

Une forte entropie peut indiquer :

- Un DGA (Domain Generation Algorithm)
- Une infrastructure malveillante

6 Behavioral and Psychological IoCs

Ces indicateurs visent à détecter les mécanismes d'ingénierie sociale.

6.1 Densité d'Urgence

Les emails malveillants utilisent fréquemment :

- urgent
- immédiatement
- action requise
- compte suspendu

L'objectif est de provoquer :

- Stress
- Panique
- Réaction impulsive

6.2 Credential Requests

Les emails de phishing cherchent souvent à récupérer :

- login
- password
- OTP
- données bancaires

La présence répétée de ce vocabulaire représente un indicateur important.

7 Content and Obfuscation IoCs

7.1 Ratio HTML/Texte

Les emails malveillants utilisent souvent :

- Beaucoup de HTML
- Des boutons cachés
- Des scripts
- Des redirections

Un ratio HTML anormal peut révéler :

- Une tentative de dissimulation
- Une redirection cachée

7.2 Majuscules Excessives

Les campagnes frauduleuses utilisent fréquemment :

- Des majuscules massives
- Des caractères spéciaux
- Des ponctuations excessives

Exemple :

URGENT!!! VERIFY YOUR ACCOUNT NOW!!!

7.3 Obfuscation Unicode

Les attaquants utilisent :

- Zero-width characters
 - Leetspeak
 - Unicode invisible
- afin de contourner :
- Les filtres lexicaux
 - Les signatures statiques

8 Metadata IoCs

8.1 Extensions Dangereuses

Certaines extensions sont fortement associées aux malwares :

- .exe
- .vbs
- .scr
- .js

Ces pièces jointes peuvent agir comme :

- Droppers
- Trojans
- Loaders
- Ransomwares

9 Mapping Attaque → IoC → Défense

Technique d'Attaque	Vecteur	IoC Défensif
Spoofing	Faux email	Reply-To mismatch
Credential Theft	Faux login	Credential keywords
Malware Delivery	Pièce jointe	Suspicious extension
DNS Bypass	URL IP directe	IP-based URL
Social Engineering	Urgence psychologique	Urgency density
Filter Evasion	Obfuscation Unicode	Unicode anomaly detection

TABLE 1 – Mapping Attaque → IoC → Défense

10 Pipeline de Détection

Le pipeline complet du système suit les étapes suivantes :

1. Réception de l'email
2. Parsing des headers
3. Extraction des URLs
4. Analyse comportementale
5. Extraction des IoCs
6. Vectorisation
7. Classification ML
8. Décision finale

11 Conclusion

Cette approche permet de transformer un simple système de classification en une véritable architecture défensive orientée cybersécurité.

Le projet ne repose pas uniquement sur des modèles statistiques, mais sur :

- Une compréhension des cyberattaques
- Une analyse comportementale
- Des mécanismes de filtrage multi-couches

— Des Indicateurs de Compromission réalistes

L'objectif final est de construire un système capable de résister aux comportements adaptatifs des attaquants tout en maintenant un faible taux de faux positifs et de faux négatifs.